

... REPORTE DE ACTIVIDAD 9

Nombre del proyecto: File path traversal, traversal sequences stripped non-recursively

Nivel: Apprentice

Nombre: Karla Vanessa Glz Espinoza

TIPO DE EXPLOTACIÓN

Path Traversal (Directory Traversal) Bypass / CWE-22: Improper Limitation of a Pathname to a Restricted Directory.

OBJETIVO DEL LABORATORIO

El objetivo de este laboratorio es vulnerar una aplicación web que implementa un mecanismo de defensa de sanitización de entradas defectuoso. Se busca evadir un filtro que elimina secuencias de salto de directorio de forma no recursiva, logrando así recuperar y leer el archivo sensible `/etc/passwd`.

EXPLICACIÓN TÉCNICA

Una técnica común de mitigación contra ataques de Path Traversal es la "sanitización" o limpieza (stripping) de las entradas del usuario. En este enfoque, el servidor web busca cadenas maliciosas conocidas, como `../`, y las elimina de la entrada antes de procesar la solicitud al sistema de archivos (OWASP Foundation, 2023).

El fallo crítico ocurre cuando esta sanitización se implementa de manera no recursiva. Un filtro no recursivo recorre la cadena de entrada una única vez. Si un atacante inyecta secuencias anidadas (nested sequences) como `....//`, el filtro identificará la secuencia central `../` y la eliminará. Sin embargo, al eliminarse el segmento interno, los caracteres adyacentes restantes (`..` por la izquierda y `/` por la derecha) colapsan y forman una nueva secuencia maliciosa `../` que el filtro ya no volverá a revisar (MITRE, 2023).

Como establece CISA (2022), las estrategias de validación basadas en listas negras (blacklisting) o reemplazo simple son inherentemente frágiles. Los atacantes pueden aplicar técnicas de ofuscación de payloads que, tras ser procesadas de forma incompleta por la aplicación, se transforman en vectores de ataque válidos, comprometiendo severamente la Confidencialidad de la información.

PROCEDIMIENTO

Paso 1: Se ingresó al entorno de pruebas provisto por Web Security Academy y se inicializó Burp Suite Community Edition para actuar como proxy de intercepción HTTP.

Paso 2: Desde la interfaz web, se navegó hacia el detalle de un producto específico para forzar la carga de la imagen respectiva. A continuación, en el historial HTTP de Burp Suite, se identificó la solicitud original de obtención del archivo (GET /image?filename=6.jpg) y se envió al módulo Repeater para su posterior edición.

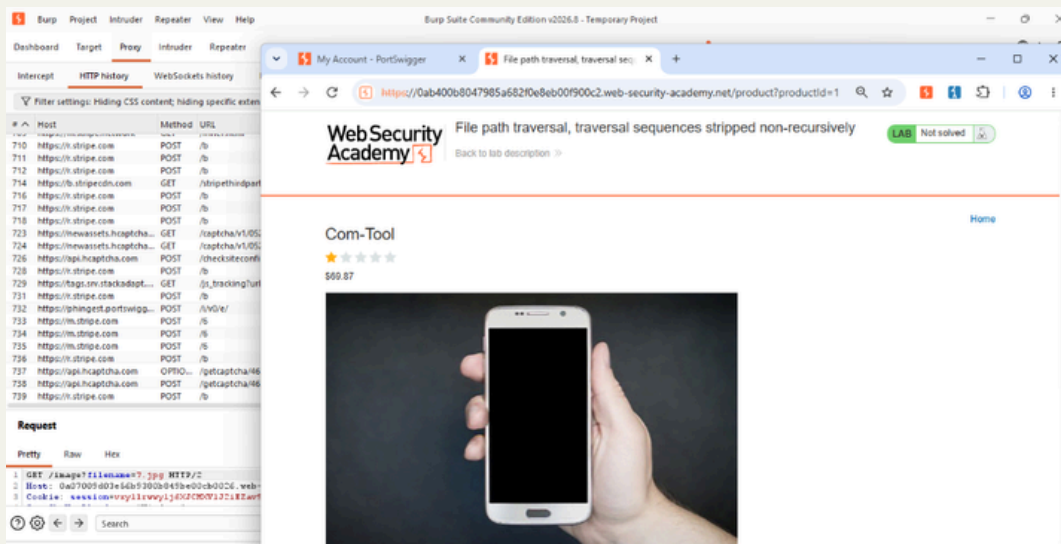


Figura 9.1 Pagina principal de la tienda en un apartado de “View details” de un producto.

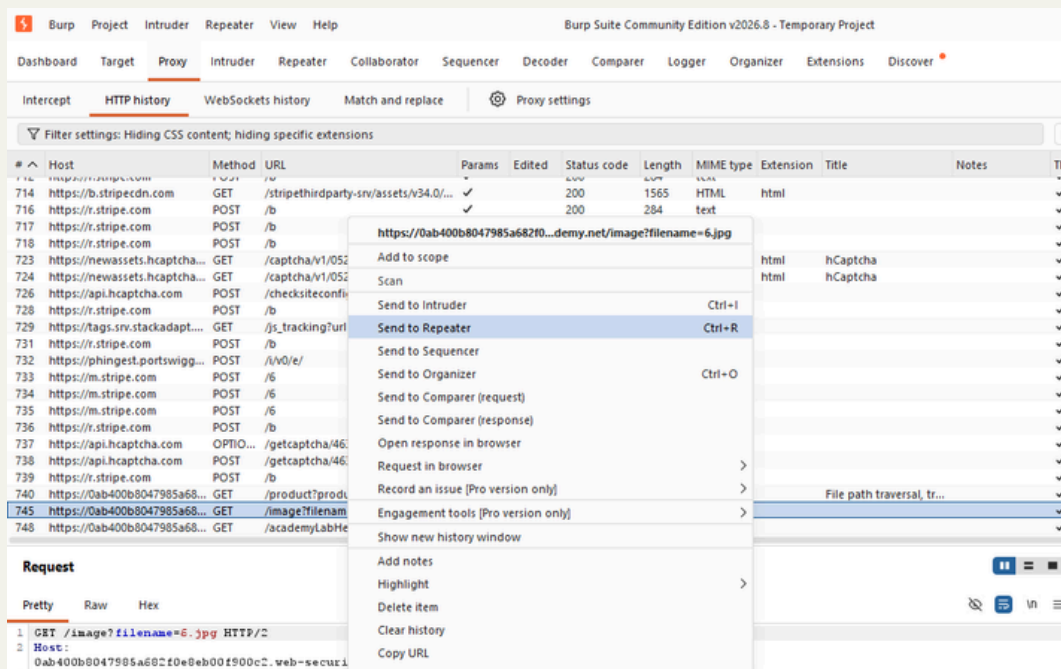


Figura 9.2 Se envió la petición a Repeater para su maipulación

Paso 3: Una vez en Repeater, se identificó que el servidor eliminaba la secuencia estándar ../. Consecuentemente, se procedió a modificar el parámetro de entrada filename, inyectando el payload ofuscado mediante secuencias anidadas//.

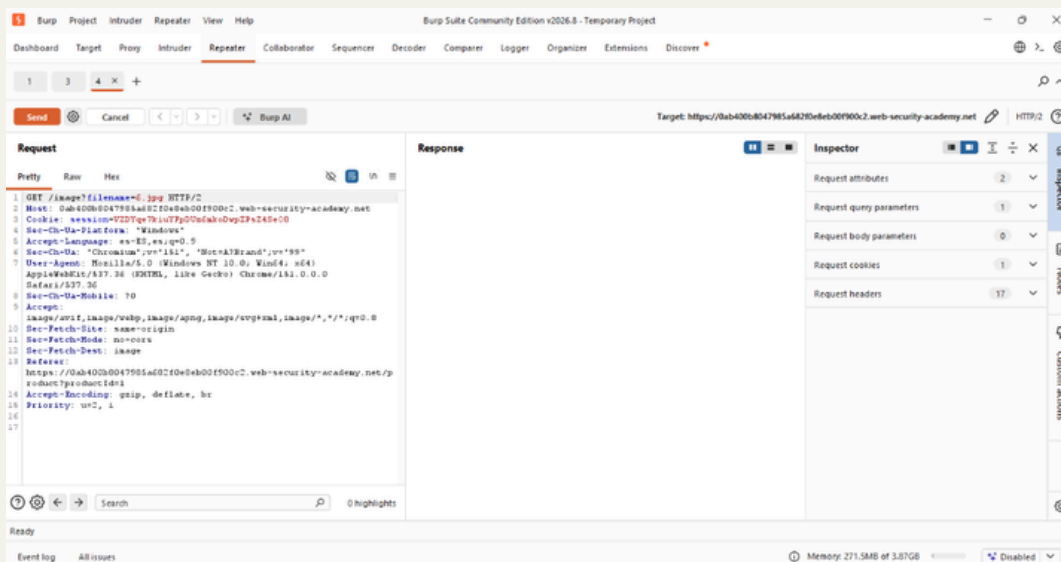


Figura 9.3 Parámetro filename original

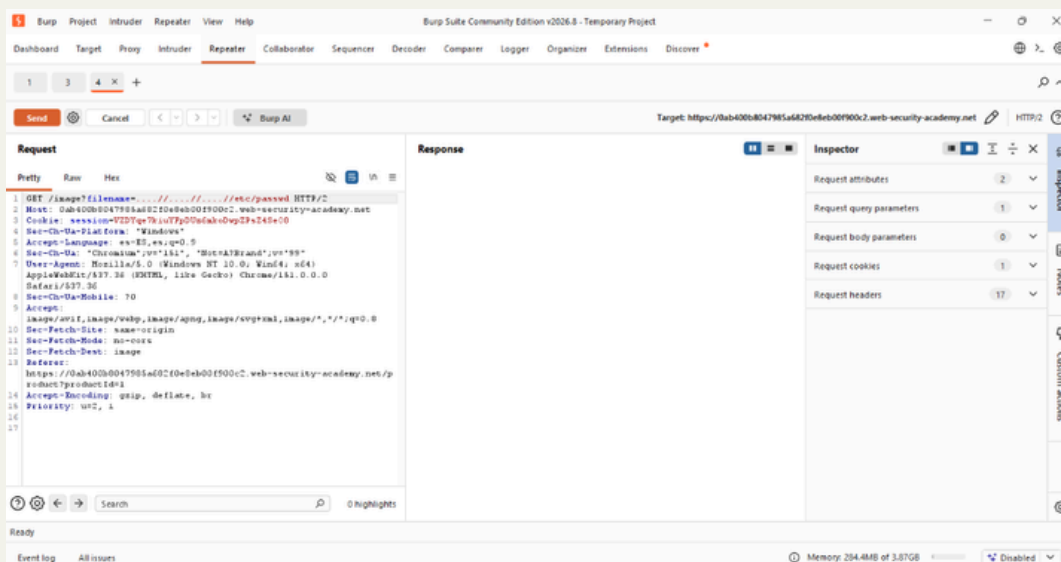


Figura 9.4 Parámetro filename modificado

Paso 4: Se envió la solicitud manipulada (GET /image?filename=....//....//....//etc/passwd). Al procesarla, el servidor eliminó la porción media no recursivamente, reestructurando internamente el ataque a una ruta Path Traversal válida y devolviendo el contenido del archivo de usuarios del sistema Linux con un estado HTTP/2 200 OK.

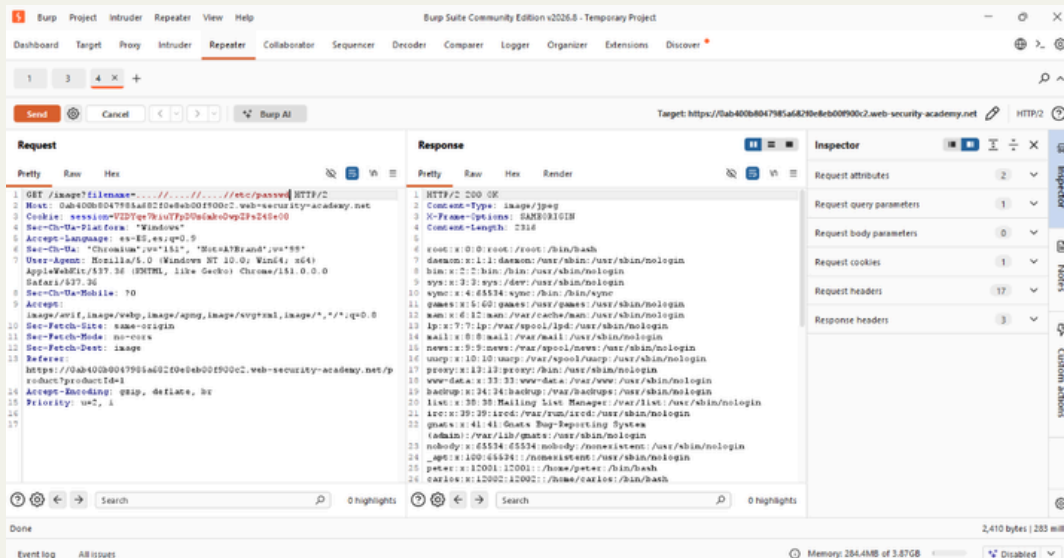


Figura 9.5 Respuesta del servidos al filname modificado

Paso 5: Finalmente, se recargó la vista del navegador, corroborando la correcta explotación de la vulnerabilidad mediante la obtención de la insignia "Lab Solved".

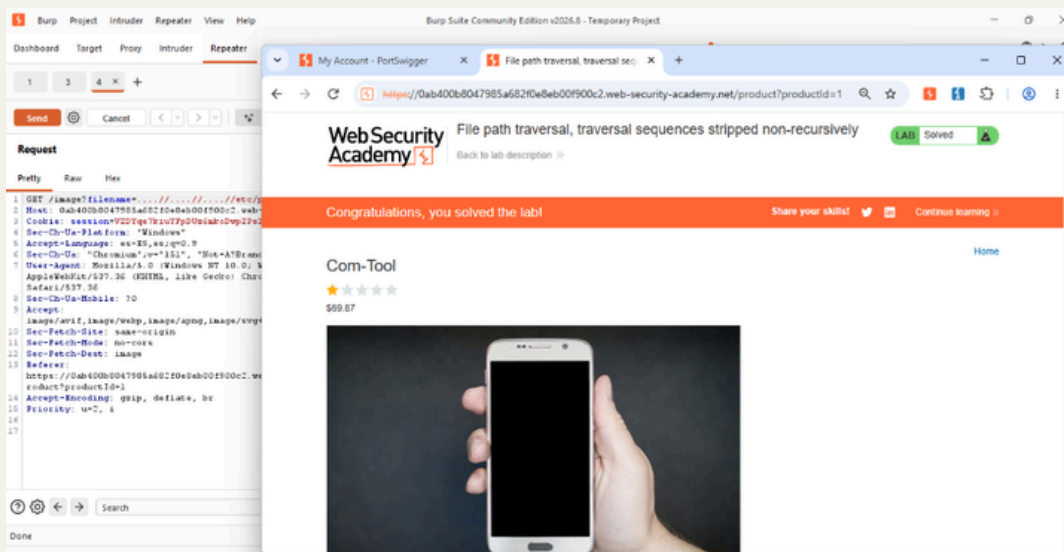


Figura 9.6 Laboratorio finalizado

EXPLICACIÓN DEL PAYLOAD

Payload utilizado://....//....//etc/passwd

La aplicación contiene una rutina de seguridad deficiente (`String.replace("../", "")`) ejecutado una sola vez). Al proporcionar la cadena anidada//, la aplicación encuentra el patrón central ../ y lo suprime.

Tras esta eliminación, los dos puntos iniciales y la barra diagonal final convergen matemáticamente para crear una nueva directiva de salto de directorio ../. Este proceso ocurre para cada uno de los tres bloques inyectados, por lo que el servidor termina interpretando y ejecutando la ruta ../../../etc/passwd. De esta manera, el sistema retrocede tres niveles jerárquicos desde su directorio de imágenes y accede al archivo raíz requerido.

MITIGACIÓN RECOMENDADA

- Validación fuerte basada en Allow-list: Como principal línea de defensa, la validación debe rechazar contundentemente (denegar acceso o lanzar error) cualquier entrada que contenga secuencias dudosas (/, \, .), en lugar de intentar "arreglar" o limpiar la entrada maliciosa. Limpiar entradas es una práctica propensa a vulnerabilidades de bypass por ofuscación (CISA, 2022).
- Utilizar identificadores indirectos: Eliminar por completo el uso de nombres de archivo suministrados por el cliente. Mapear cada recurso a un UUID o identificador en base de datos previene la superficie de ataque (OWASP Foundation, 2023).
- Restringir permisos del proceso (Sandboxing/Chroot): Configurar el servicio web o contenedor de la aplicación para que se ejecute en un entorno de sistema de archivos aislado (jaula chroot), asegurando que, incluso si un ataque de Path Traversal es exitoso, el atacante no pueda navegar fuera del directorio limitado de la aplicación.

REFERENCIAS

- CISA. (2022). Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Cybersecurity and Infrastructure Security Agency. <https://www.cisa.gov/uscert/bsi/articles/knowledge/coding-practices/path-traversal>
- MITRE. (2023). CWE-22: Improper Limitation of a Pathname to a Restricted Directory ('Path Traversal'). Common Weakness Enumeration. <https://cwe.mitre.org/data/definitions/22.html>
- OWASP Foundation. (2023). Path Traversal. Open Worldwide Application Security Project. https://owasp.org/www-community/attacks/Path_Traversal